

Graeme Anderson

Jeff Franklin

CPRE 2340

4/12/2026

Biohacking: Cybersecurity in Medical Biotechnology

In January of 2025, hospitals across the U.S. and Europe were unknowingly running hacked equipment. Their patients were having their health data – heart rate, blood pressure, ECG readings – silently transmitted to an unknown server. The Cybersecurity and Infrastructure Security Agency (CISA) reported a backdoor built into the Contec CMS8000 patient monitor, produced by Contec Medical Systems, a Chinese medical device manufacturer. This set of vulnerabilities allowed for a complete firmware overwrite and allowed for exfiltration of patient data to a hardcoded IP address that was believed to be registered to a third-party Chinese university (*CISA Fact Sheet*, 2). As an aspiring Cybersecurity professional, this story is directly impactful to how I view my work and the work of my field, and I may read about or even potentially witness similar events in my professional career. The Contec backdoor revealed a deep flaw in medical device security – an oversight that endangered vulnerable patients, violated fundamental privacy rights, and expose an urgent need for stronger security vetting of medical devices before they ever reach a hospital floor.

The Contec CMS8000 is a device, manufactured by Contec Medical Systems, a company based in Qinhuaangdao, China, designed to continuously monitor a patient's most critical vital signs, including heart rate, blood oxygenation, and ECG readings. The vulnerabilities CISA discovered, however, exposed that the device was doing far more than monitoring. The FDA identified three categories of risk: device denial, remote takeover, and unauthorized data exfiltration. Critically, the agency noted that the CMS8000 was only authorized for wired ethernet use — meaning any wireless-capable units deployed in hospitals

were operating outside FDA approval entirely (FDA, 2025). Hospitals trusted these devices to be secure – a trust that Contec betrayed.

These advisories from the FDA and CISA reported the general scope of the issues, but the exact technical details of the vulnerabilities were documented by cybersecurity firm Claroty's Team82, who independently acquired and physically disassembled a CMS8000 unit to analyze its firmware. Their investigation found that the hard-coded IP addresses — 202.114.4.119 and 202.114.4.120 — were actually documented in Contec's own operator manuals, where hospitals were instructed to configure their internal Central Management Systems to those addresses (Team82, Claroty, 2025). A WHOIS lookup of that subnet traces it to Tsinghua University in China (ICANN, 2026) — not to any known Contec server. Team82 concluded that this was most likely severe negligence in design rather than deliberate intent: Contec had hard-coded a routable public IP address where a private internal network address should have been, meaning any hospital that did not configure its own CMS in line with Contec standards would inadvertently route sensitive patient data out to the open internet. Whether accidental or intentional, Team82 demonstrated in a proof-of-concept that the flaw could be exploited to achieve full remote code execution on the monitor — including faking patient vitals or launching a ransomware attack that rendered the device completely inoperable (Team82, Claroty, 2025).

The impacts of this discovery were immediate and could have been potentially devastating for many individuals. Hospital patients may have had their personal health information stolen or their care could have been severely impacted via a ransomware attack or other deactivation of the monitor. These patients had no ability to exercise their right to privacy over their own health data — data that was being quietly moved and stored externally, effectively censoring any knowledge of these transmissions from the people most affected. The complete absence of disclosure suppressed patients' and staff's freedom of expression on an issue that directly endangered them — you cannot speak to a risk you are never told exists. This scenario maps directly to the Ethical OS **Surveillance State** risk zone — a framework that identifies technologies enabling mass data collection without user knowledge or consent as a primary

ethical threat. Patients connected to these monitors had no awareness that their biometric data was being transmitted externally, stripping them of any meaningful ability to consent or object. The hospital staff could have faced an extremely fraught situation, having to provide healthcare during an attack on a critical tool. The situation and resulting fallout are an intense pressure on entire hospitals: they face their own tough decision whether to spend time and effort reconfiguring their network to prevent this vector, replace the Contec monitors entirely, or face severe risk from doing nothing. A second risk zone applicable to this event is **Hateful and Criminal Actors** — the demonstrated ability to fake patient vitals or disable the monitor entirely represents a tool that, in malicious hands, could be used to target specific individuals or destabilize entire care networks (Team82, Claroty, 2025).

From Contec, the response was nearly nonexistent. Throughout the disclosure process, the FDA and CISA communicated entirely on the company's behalf — Contec made no public statements and offered no independent mitigations. The regulatory and legal consequences, however, escalated rapidly. On January 30th, CISA recommended removal of affected devices from hospital networks, with no patch available (CISA, 2025). In June 2025, Florida Attorney General James Uthmeier subpoenaed both Contec and its American reseller Epsimed under Florida's Deceptive and Unfair Trade Practices Act, accusing the company of marketing the monitors as FDA-approved when they were not, and of concealing serious security vulnerabilities from consumers (Florida AG Press Release, 2025). When the FDA physically inspected Contec's facility in China that same month, inspectors found systemic failures in quality management, software validation, and complaint handling. A formal Warning Letter issued to Contec's CEO in October 2025 concluded that all devices manufactured by the firm are now subject to detention and refusal of entry into the United States (FDA Warning Letter, 2025). A patch was ultimately announced in July 2025, but it works solely by removing all networking functionality from the device — a remedy that speaks more to the unfixability of the design than to any genuine remediation effort by Contec (AHA News, July 2025). This pattern of silence, concealment, and regulatory failure paints a clear picture of an organization that prioritized market access over patient safety.

Contec made a litany of errors in their design, and unintentionally or not, created the potential for a surge of health security attacks. Team82 identified the usage of routable public IP addresses where RFC1918 private address ranges (10.x.x.x, 192.168.x.x) should have been — a gross violation of basic networking standards that any competent device manufacturer should catch before production (Team82, Claroty, 2025). The second glaring issue was the method of transmission to those addresses: the device broadcast Personal Health Information in plaintext over an unencrypted connection. This is utterly indefensible under any modern standard, including HIPAA. TLS encryption has been an industry standard for decades and is entirely implementable on a device already complex enough to monitor cardiac function. The FDA's failure to catch these issues prior to market clearance also represents a critical gap in pre-market oversight — particularly given that Team82 had publicly demonstrated a working exploit of this exact design flaw at Claroty's Nexus Conference in 2022, three years before CISA's disclosure (Team82, Claroty, 2025). A mandatory pre-market independent security audit would likely have surfaced this vulnerability before a single patient was exposed. None of these measures — private IP addressing, encrypted transmission, pre-market third-party audits — require resources beyond what any device manufacturer selling into U.S. markets should be expected to provide. These are not aspirational standards. They are the baseline of competent design, and their absence here endangered millions of patients.

This event is not an isolated incident; health systems are continually under attack from external threats. PHI is extremely valuable data, and hospital IT departments are often spread thin and under-resourced. The FDA needs to protect them before these issues make it to the hospital floor — security must be paramount for new devices, and the FDA must enforce their requirements on safety before any product reaches a patient's bedside. As a new cybersecurity professional just entering the space, this is a clear message about the stakes of working in critical infrastructure. Failures here can mean massive damage to real people. The systems that I help build and secure may one day be involved in life-or-death situations, and a mistake on my part could cause that system to harm people — even people I know and love. Technology in healthcare is a critical tool, and the security of that field is a profound

responsibility. There must be serious accountability in that space, where security is treated not as an afterthought, but as the first obligation to patients and the people who care for them.

Works Cited

- American Hospital Association. "CISA, FDA Warn of Vulnerabilities in Contec Patient Monitors." *AHA News*, 31 Jan. 2025, www.aha.org/news/headline/2025-01-31-cisa-fda-warn-vulnerabilities-contec-patient-monitors.
- American Hospital Association. "FDA Announces Software Patch Available for Contec, Epsimed Patient Monitors to Address Vulnerabilities." *AHA News*, 3 Jul. 2025, www.aha.org/news/headline/2025-07-03-fda-announces-software-patch-available-contec-epsimed-patient-monitors-address-vulnerabilities.
- "Contec Health CMS8000 Patient Monitor (Update A)." *CISA*, Cybersecurity and Infrastructure Security Agency, 25 Feb. 2025, www.cisa.gov/news-events/ics-medical-advisories/icsma-25-030-01.
- "Contec CMS8000 Contains a Backdoor." *CISA Fact Sheet*, Cybersecurity and Infrastructure Security Agency, 30 Jan. 2025, www.cisa.gov/sites/default/files/2025-01/fact-sheet-contec-cms8000-contains-a-backdoor-508c.pdf.
- "CISA Releases Fact Sheet Detailing Embedded Backdoor Function of Contec CMS8000 Firmware." *CISA*, Cybersecurity and Infrastructure Security Agency, 30 Jan. 2025, www.cisa.gov/news-events/alerts/2025/01/30/cisa-releases-fact-sheet-detailing-embedded-backdoor-function-contec-cms8000-firmware.
- "Cybersecurity Vulnerabilities with Certain Patient Monitors from Contec and Epsimed: FDA Safety Communication." *FDA*, U.S. Food and Drug Administration, 2025, www.fda.gov/medical-devices/safety-communications/cybersecurity-vulnerabilities-certain-patient-monitors-contec-and-epsimed-fda-safety-communication.

Team82. "Do the CONTEC CMS8000 Patient Monitors Contain a Chinese Backdoor? The Reality is More Complicated..." *Claroty*, 2 Feb. 2025, claroty.com/team82/research/are-contec-cms8000-patient-monitors-infected-with-a-chinese-backdoor-the-reality-is-more-complicated.

"WHOIS Lookup: 202.114.4.119." *ICANN Lookup*, Internet Corporation for Assigned Names and Numbers, lookup.icann.org/en/lookup.

Uthmeier, James. "Attorney General James Uthmeier Issues Subpoenas to Companies Selling Medical Devices Sending Patient Data to Communist China." *My Florida Legal*, 16 Jun. 2025, www.myfloridalegal.com/newsrelease/attorney-general-james-uthmeier-issues-subpoenas-companies-selling-medical-devices.

Zuckerman, Bram. "Contec Medical Systems Co., Ltd. — Warning Letter 717941." *U.S. Food and Drug Administration*, 2 Oct. 2025, www.fda.gov/inspections-compliance-enforcement-and-criminal-investigations/warning-letters/contec-medical-systems-co-ltd-717941-10022025.